

Setup Laboratorio di Analisi Malware e Identificazione IOC

Nicola Madonna

03/08/2026

1 Esercizio del Giorno: Creare uno snapshot "Clean" della VM pronta all'uso e avviare lo script malwareRepo.ps1

1.1 Obiettivo

L'obiettivo dell'esercizio è configurare l'ambiente FlareVM per l'analisi malware e identificare Indicatori di Compromissione (IOC) tramite analisi del Registro di Windows e triage su VirusTotal.

1.2 Ambiente di Lavoro

- **Sistema operativo:** Windows 11
- **Ambiente:** FlareVM (macchina virtuale isolata)

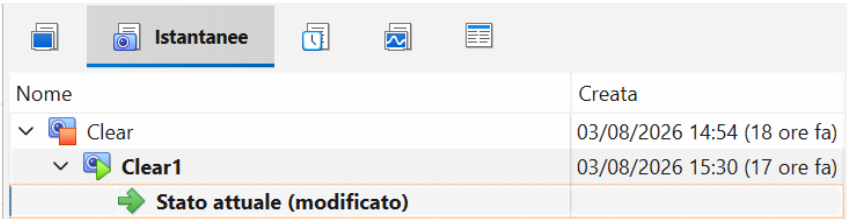
1.3 Attività 1: Creazione dello Snapshot "Clean"

1.4 Descrizione

Prima di eseguire qualsiasi operazione potenzialmente rischiosa (download e scompattamento di campioni malware, modifiche al registro), è stato creato uno snapshot della macchina virtuale. Questo garantisce la possibilità di ripristinare rapidamente un ambiente pulito in caso di problemi, evitando di dover reinstallare l'intera FlareVM.

1.4.1 Procedura

1. Apertura del pannello *Istantanee* del software di virtualizzazione.
2. Creazione di un'istantanea di base (**Clear**), seguita da una seconda istantanea (**Clear1**) a macchina configurata e pronta all'uso.
3. Verifica della presenza delle istantanee nell'elenco, con relativa data e ora di creazione.



Istantanee	
Nome	Crea
✓ Clear	03/08/2026 14:54 (18 ore fa)
✓ Clear1	03/08/2026 15:30 (17 ore fa)
➡ Stato attuale (modificato)	

Figura 1: Elenco delle istantanee create sulla macchina virtuale FlareVM: **Clear** e **Clear1**, con lo stato attuale modificato successivamente.

1.4.2 Risultato

Le istantanee sono state create correttamente e sono disponibili per un eventuale ripristino, garantendo un ambiente di analisi sicuro e reversibile.

1.5 Attività 2: Download del Repository Malware

1.5.1 Descrizione

Per popolare l'ambiente di analisi con campioni malware reali (ma controllati), è stato eseguito lo script `malwareRepo.ps1` presente sul Desktop della FlareVM. Lo script effettua il download di un repository Git pubblico contenente campioni malware categorizzati per tipologia.

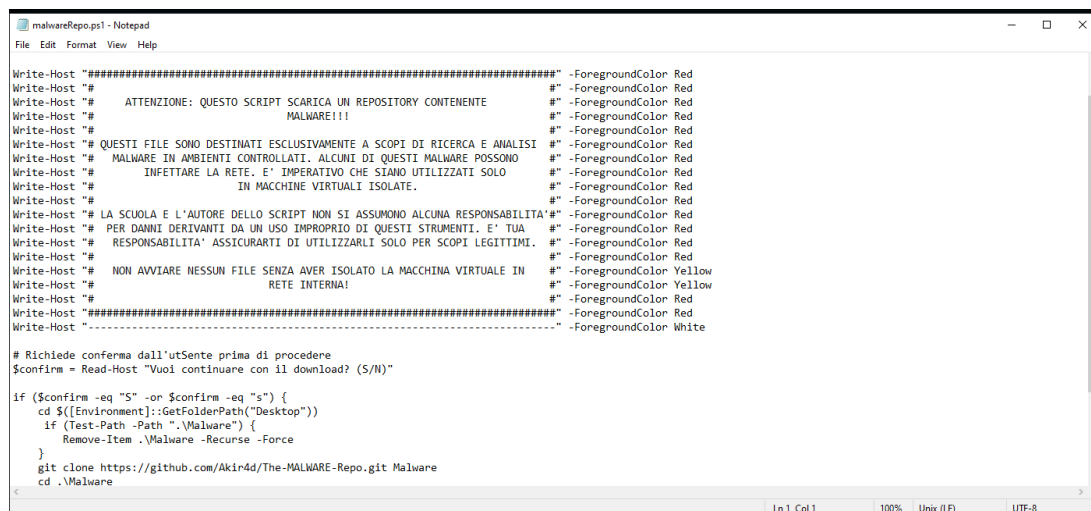
1.5.2 Contenuto dello Script

Lo script, prima di procedere, mostra un avviso di sicurezza e richiede conferma esplicita all'utente. Le operazioni principali eseguite sono:

- Visualizzazione di un avviso relativo ai rischi legati all'uso di malware reali.
- Richiesta di conferma interattiva (S/N) prima di procedere al download.
- Spostamento nella cartella Desktop dell'utente.
- Rimozione di un'eventuale cartella **Malware** preesistente.
- Clonazione del repository Git:

```
git clone https://github.com/Akir4d/The-MALWARE-Repo.git Malware
```

1.5.3 Evidenza – Script



```
Write-Host "#####" -ForegroundColor Red
Write-Host "# ATTENZIONE: QUESTO SCRIPT SCARICA UN REPOSITORY CONTENENTE MALWARE!!!" -ForegroundColor Red
Write-Host "# QUESTI FILE SONO DESTINATI ESCLUSIVAMENTE A SCOPI DI RICERCA E ANALISI" -ForegroundColor Red
Write-Host "# MALWARE IN AMBIENTI CONTROLLATI. ALCUNI DI QUESTI MALWARE POSSONO INFETTARE LA RETE. E' IMPERATIVO CHE SIANO UTILIZZATI SOLO IN MACCHINE VIRTUALI ISOLATE." -ForegroundColor Red
Write-Host "# LA SCUOLA E L'AUTORE DELLO SCRIPT NON SI ASSUMONO ALCUNA RESPONSABILITA' PER DANNI DERIVANTI DA UN USO IMPROPRIO DI QUESTI STRUMENTI. E' TUA RESPONSABILITA' ASSICURARTI DI UTILIZZARLI SOLO PER SCOPI LEGITTIMI." -ForegroundColor Red
Write-Host "# NON AVVIARE NESSUN FILE SENZA AVER ISOLATO LA MACCHINA VIRTUALE IN RETE INTERNA!" -ForegroundColor Yellow
Write-Host "# RICHIEDE CONFERMA DALL'UTENTE PRIMA DI PROCEDERE" -ForegroundColor Red
Write-Host "$confirm = Read-Host "Vuoi continuare con il download? (S/N)" -ForegroundColor White

if ($confirm -eq "S" -or $confirm -eq "s") {
    cd $([Environment]::GetFolderPath("Desktop"))
    if (Test-Path -Path ".\Malware") {
        Remove-Item .\Malware -Recurse -Force
    }
    git clone https://github.com/Akir4d/The-MALWARE-Repo.git Malware
    cd .\Malware
}
```

Figura 2: Contenuto dello script `malwareRepo.ps1`, con avviso di sicurezza e comando di clonazione del repository.

1.5.4 Evidenza – Repository Scaricato

Al termine dell'esecuzione, la cartella **Malware** risulta popolata con diverse sottocartelle organizzate per categoria di minaccia (es. *Banking-Malware*, *Ransomware*, *RAT*, *Spyware*, *Trojan*, *Worm*, ecc.), oltre ad alcuni file eseguibili e archivi compressi di esempio.

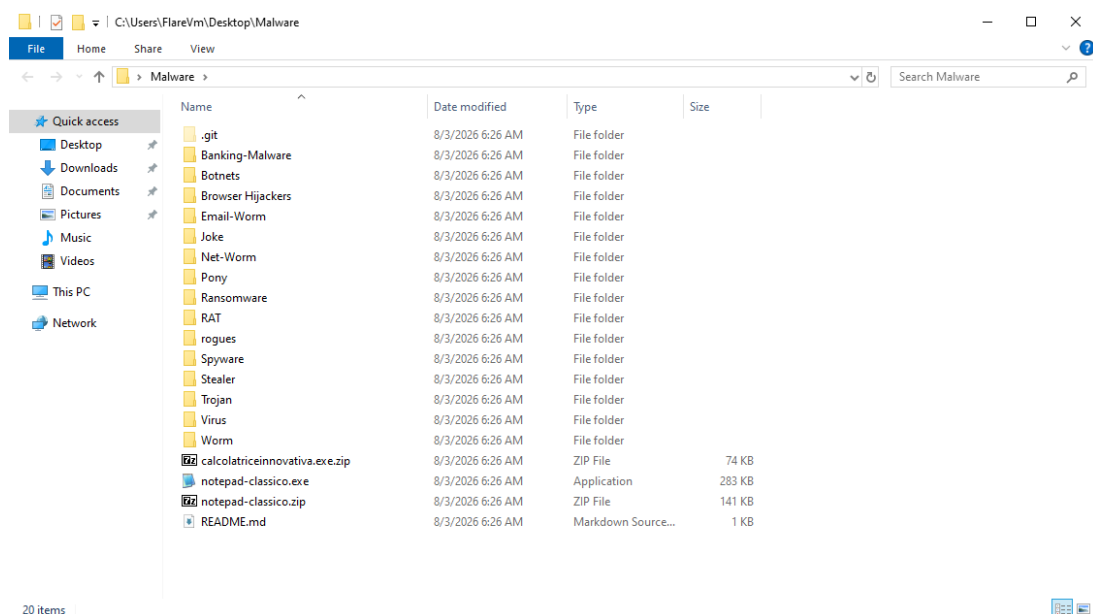


Figura 3: Contenuto della cartella **Malware** dopo l'esecuzione dello script, organizzata per categorie di minaccia.

1.5.5 Risultato

Il repository è stato scaricato correttamente e la cartella **Malware** contiene i campioni organizzati per tipologia, pronti per le successive fasi di analisi (scompattamento, calcolo hash e ricerca IOC su VirusTotal).

1.6 Conclusioni

Le attività di setup dell'ambiente sono state completate con successo: la creazione dello snapshot garantisce un punto di ripristino sicuro, mentre il download del repository malware fornisce i campioni necessari per proseguire con l'analisi e l'identificazione degli Indicatori di Compromissione nelle fasi successive del laboratorio.

2 Attività extra

2.1 Simulazione di una chiave di persistenza manuale in HKCU Run con regedit

Obiettivo: creare manualmente una voce di persistenza nella chiave di registro HKCU\...\Run e verificarne l'effetto al riavvio del sistema, per comprendere una delle tecniche di persistenza più comuni utilizzate dal malware.

2.1.1 Descrizione dell'attività

Una delle tecniche di persistenza più comuni utilizzate dal malware consiste nell'aggiunta di una voce nella chiave di registro Run, che consente l'esecuzione automatica di un programma ad ogni login dell'utente. Per simulare questo comportamento in modo sicuro, è stata creata manualmente una voce di registro puntando all'eseguibile `calc.exe` (Calcolatrice di Windows).

2.1.2 Percorso di registro utilizzato

```
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
```

2.1.3 Procedura

1. Apertura di `regedit`.
2. Navigazione fino alla chiave `HKCU\Software\Microsoft\Windows\CurrentVersion\Run`.
3. Creazione di un nuovo valore di tipo `REG_SZ` con:
 - **Nome:** `Calculator`
 - **Dati:** `C:\Windows\System32\calc.exe`
4. Riavvio della macchina virtuale.
5. Verifica dell'avvio automatico della Calcolatrice al login.

2.1.4 Evidenze

Name	Type	Data
 (Default)	REG_SZ	(value not set)
 ZoomIt	REG_SZ	C:\Tools\sysinternals\ZoomIt64.exe
 Calculator	REG_SZ	C:\Windows\System32\calc.exe

Figura 4: Chiave di registro `Run` con il valore `Calculator` configurato per l'avvio automatico di `calc.exe`.

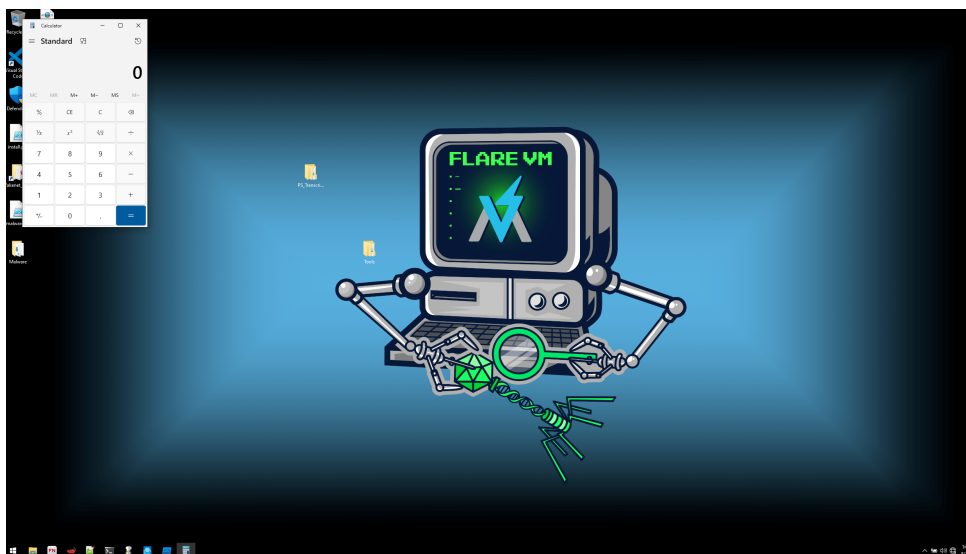


Figura 5: Verifica dell'esecuzione automatica: la Calcolatrice si apre al riavvio del sistema, confermando l'efficacia della tecnica di persistenza.

2.1.5 Risultato

Al riavvio della macchina, l'applicazione Calcolatrice si è avviata automaticamente, confermando che la voce di registro creata manualmente in `HKCU\...\Run` è stata eseguita correttamente dal sistema operativo. Questo conferma il funzionamento della tecnica di persistenza **T1547.001 – Registry Run Keys / Startup Folder** secondo il framework MITRE ATT&CK.

2.1.6 Conclusioni

Questo test dimostra in modo pratico e sicuro come un malware possa ottenere persistenza sul sistema senza richiedere privilegi elevati, semplicemente scrivendo una voce nella chiave **HKCU Run**. Questa tecnica è comunemente osservata nei report di VirusTotal, nella sezione *Behavior*, e rappresenta uno degli IOC (Indicatori di Compromissione) più frequenti da ricercare durante l'analisi di un campione malevolo.

2.2 Analisi dei campioni malware e identificazione IOC

Per l'attività di analisi sono stati selezionati 5 campioni malware dal repository scaricato, suddivisi in 3 categorie: Ransomware(CryptoLocker.exe Tabella 1, Dharma.exe Tabella 2), RAT(CrimsonRat.exe Tabella 3, RevengeRAT.exe Tabella 4) e Trojan(FlashKiller.exe Tabella 5).

Obiettivi: per ciascun campione è stato calcolato l'hash SHA256, effettuata la ricerca su VirusTotal e analizzati i tab *Detection*, *Relations* e *Behavior*.

2.2.1 CryptoLocker.exe (Ransomware)

Campo	Dettaglio
Hash (SHA256)	d765e722e295969c0a5c2d90f549db8b89ab617900bf4698db41c7cdad993bb9
Detection Ratio	65/69
Domini/URL C2	ngoefjwghdxmtq.biz (3/70), swciqckbecjat.co.uk (2/70) – pattern DGA
Persistenza	Tag persistence rilevato
Comportamento	DGA (1262 query DNS), dropped: 1 PE_EXE, 1 RTF (probabile ransom note), IDS/Sigma rules High severity

Tabella 1: IOC identificati per CryptoLocker.exe

2.2.2 Dharma.exe (Ransomware)

Campo	Dettaglio
Hash (SHA256)	6fb303dd8ba36381948127d44bd8541e4a1ab8af07b46526ace08458f2498850
Detection Ratio	59/69
Domini/URL C2	epoolsoft.com – abuso del tool legittimo PCHunter (T1562 Impair Defenses)
Persistenza	Tag calls-wmi , possibile persistenza via WMI
Comportamento	spreader , self-delete ; 6 Mitre Signatures High (il più alto tra i campioni analizzati); dropped ~150 file (incl. 1 JavaScript, 1 PE_EXE)

Tabella 2: IOC identificati per Dharma.exe

2.2.3 CrimsonRat.exe (RAT)

Campo	Dettaglio
Hash (SHA256)	dc31e710277eac1b125de6f4626765a2684d992147691a33964e368e5f269cba
Nome su disco	hbraeiwas.exe (nome fittizio, tecnica anti-detection)
Detection Ratio	59/69
Domini/IP C2	Nessun C2 esterno chiaro; scansione rete locale (192.168.0.x)
Persistenza	Non individuata chiave specifica
Comportamento	spreader + service-scan → movimento laterale in rete (T1046); dropped 97+ file, 1 ZIP, 1 PE_EXE

Tabella 3: IOC identificati per CrimsonRat.exe

2.2.4 RevengeRAT.exe (RAT)

Campo	Dettaglio
Hash (SHA256)	9b4826b8876ca2f1378b1dfe47b0c0d6e972bf9f0b3a36e299b26fbc86283885
Detection Ratio	58/70
Domini/URL C2	tcp://0.tcp.ngrok.io:19521/ – C2 tramite tunnel ngrok
Persistenza	Tag persistence + calls-wmi
Comportamento	ssh-communication , obfuscated , exploit ; 1 Sigma Critical + 7 High (il più severo tra i campioni analizzati); dropped 1 LNK, 414+ file

Tabella 4: IOC identificati per RevengeRAT.exe

2.2.5 FlashKiller.exe (Trojan)

Campo	Dettaglio
Hash (SHA256)	353df4f186c06a626373b0978d15ec6357510fd0d4ac54b63217b37142ab52d3
Nome su disco	Retrac cheet.exe (nome fittizio)
Detection Ratio	61/70
Domini/IP C2	Nessun C2 esterno chiaro; contatti su rete locale (192.168.0.x)
Persistenza	Nessuna persistenza esplicita rilevata
Comportamento	Comportamento dinamico minimo (9 Info only, nessuna signature Low/Medium/High) nonostante detection statica molto alta – possibile evasione sandbox

Tabella 5: IOC identificati per FlashKiller.exe

2.2.6 Osservazioni conclusive

L'analisi dei 5 campioni ha permesso di individuare diversi pattern ricorrenti tipici del malware moderno:

- **Tecnica DGA (Domain Generation Algorithm):** osservata in CryptoLocker.exe, con un volume anomalo di query DNS (1262) verso domini generati casualmente, utilizzata per rendere più difficile il blocco dell'infrastruttura C2 (Command and Control).

- **Abuso di strumenti legittimi (LOLBins):** Dharma.exe contatta `epoolsoft.com`, sito del tool legittimo PCHunter, spesso abusato per disabilitare le difese del sistema (tecnica MITRE T1562).
- **C2 tramite servizi di tunneling:** RevengeRAT.exe utilizza il servizio *ngrok* per esporre un canale di controllo remoto senza necessità di infrastruttura dedicata, tecnica comune nei RAT di più semplice reperibilità.
- **Scansione della rete locale:** sia CrimsonRat.exe che FlashKiller.exe mostrano tentativi di contatto verso indirizzi IP privati (192.168.0.x), indicativi di comportamento di ricognizione/movimento laterale (T1046).
- **Discrepanza tra detection statica e comportamento dinamico:** FlashKiller.exe, pur avendo il detection ratio più alto (61/70), mostra il comportamento dinamico più povero in sandbox, suggerendo possibili tecniche di evasione dell'ambiente di analisi.
- **Persistenza:** coerentemente con il test manuale effettuato in precedenza sulla chiave `HKCU\...\Run`, diversi campioni (CryptoLocker.exe, Dharma.exe, RevengeRAT.exe) presentano tag comportamentali legati a persistenza e uso di WMI, confermando quanto osservato empiricamente nella prima parte del laboratorio.

Il campione con il profilo di rischio complessivo più elevato risulta **RevengeRAT.exe**, per la presenza di una regola Sigma di severità Critical e il maggior numero di segnalazioni High, mentre **Dharma.exe** si distingue per l'elevato numero di Mitre Signatures High e per il comportamento di tipo *spreader*.

2.3 Analisi dettagliata dei campioni malware

Premessa metodologica: i nomi dei file nel repository sono etichette date da chi ha creato la raccolta, non necessariamente corrispondono alla famiglia reale. Le detection dei vendor e il comportamento osservato sono più affidabili del nome file.

2.3.1 CryptoLocker.exe – Ransomware

Famiglia: CryptoLocker è il capostipite del ransomware moderno (2013), il primo a combinare cifratura asimmetrica robusta e pagamento in criptovaluta. L'infrastruttura originale fu smantellata nel 2014 con l'operazione Tovar, ma il nome viene usato genericamente per molte varianti successive.

Cosa dicono i dati raccolti:

- Le detection dei vendor sono coerenti: `Win32/Filecoder.BQ`, `Trojan-Ransom.Cryptolocker.H`, `Trojan.Encoder.304`. “Filecoder” ed “Encoder” indicano esplicitamente capacità di cifratura file.
- Il threat label `trojan.blocker/bbpc` suggerisce anche una componente **blocker** (schermata di blocco), tipica delle varianti più vecchie o dei falsi CryptoLocker.
- **1262 query DNS** con domini alfanumerici casuali → DGA confermato. Il DGA serve a garantire resilienza al C2: anche se i domini noti vengono sinkholed, il malware ne genera continuamente di nuovi. Il tag `nxdomain` conferma che la maggior parte delle risoluzioni fallisce (i domini non sono registrati) – comportamento atteso su un campione vecchio la cui infrastruttura è morta.
- I dropped file **RTF** + **TXT** sono con ogni probabilità la ransom note.
- `via-tor` → il pagamento/comunicazione passa per rete Tor, per anonimizzare gli operatori.

Tecniche MITRE rilevanti: T1486 (Data Encrypted for Impact), T1568.002 (Dynamic Resolution: DGA), T1090.003 (Multi-hop Proxy via Tor).

2.3.2 Dharma.exe – Ransomware

Famiglia: Dharma (noto anche come CrySiS) è una famiglia ransomware attiva dal 2016, distribuita per anni come **RaaS** (Ransomware-as-a-Service). Il suo vettore d'attacco caratteristico è il **bruteforcing di RDP esposto su Internet**, non il phishing di massa – colpisce quindi soprattutto PMI con RDP mal configurato.

Cosa dicono i dati raccolti:

- Il contatto verso **epoolsoft.com** è il dato più interessante: PCHunter è un tool **legittimo** di ispezione kernel/processi, spesso portato dagli operatori Dharma per **terminare processi di antivirus ed EDR** prima della cifratura. È un esempio da manuale di **BYOVD/LOLBin abuse**.
- Il tag **spreader** è coerente con la fase di movimento laterale: Dharma tipicamente cifra anche share di rete e unità mappate.
- **calls-wmi** → WMI è usato sia per ricognizione (elenco processi, dischi) sia per esecuzione remota.
- **self-delete** → anti-forense, il binario si rimuove dopo l'esecuzione.
- **6 Mitre Signatures High** e ~150 dropped file (incluso uno JavaScript) indicano una catena multi-stadio, non un singolo eseguibile monolitico.

Tecniche MITRE rilevanti: T1486 (Data Encrypted for Impact), T1562.001 (Impair Defenses: Disable or Modify Tools), T1047 (WMI), T1070.004 (Indicator Removal: File Deletion), T1021.001 (Remote Services: RDP).

2.3.3 CrimsonRat.exe – RAT

Famiglia: CrimsonRAT è associato a **Transparent Tribe (APT36)**, gruppo APT che storicamente ha preso di mira entità governative e militari nel subcontinente indiano. È scritto in .NET e distribuito tipicamente via documenti Office malevoli.

Cosa dicono i dati raccolti:

- Il tag **assembly** conferma la natura **.NET** – coerente con la famiglia. È un dettaglio importante perché i binari .NET sono facilmente decompilabili (dnSpy, ILSpy), il che li rende ottimi campioni didattici per l'analisi statica.
- Il nome su disco **hbraeiwas.exe** (stringa casuale) è tipico dell'offuscamento del nome file per evadere detection basate su path/nome.
- **service-scan + spreader + i contatti verso 192.168.0.x** → la sandbox ha catturato attività di **ricognizione della rete locale**. Un RAT vuole mappare l'ambiente per identificare target di valore.
- La detection sandbox riporta esplicitamente **1 RAT** e **1 Evader**, confermando sia la funzione sia le capacità anti-analisi (**detect-debug-environment, long-sleeps**).

Tecniche MITRE rilevanti: T1219 (Remote Access Software), T1046 (Network Service Discovery), T1497 (Virtualization/Sandbox Evasion), T1105 (Ingress Tool Transfer).

2.3.4 RevengeRAT.exe – RAT (il più severo del set)

Famiglia: RevengeRAT (o Revetrat) è un RAT **commodity**, distribuito gratuitamente/a basso costo su forum underground dal 2016. Anche questo è .NET. Proprio perché è alla portata di attaccanti poco skillati, è estremamente diffuso.

Cosa dicono i dati raccolti:

- `tcp://0.tcp.ngrok.io:19521/` è l'**IOC più significativo di tutto il laboratorio**. Ngrok è un servizio legittimo di tunneling che espone un servizio locale su un endpoint pubblico. Un attaccante dietro NAT domestico, senza IP statico né VPS, può così ospitare il server C2 sul proprio PC. Il porto alto (19521) è assegnato dinamicamente da ngrok.
 - **Implicazione difensiva:** questo rende il blocco per IP inutile (l'IP è di ngrok, condiviso con migliaia di utenti legittimi). La detection efficace passa per il monitoraggio DNS di `*.ngrok.io` – spesso una policy aziendale sensata è bloccare del tutto i domini di tunneling se non ci sono usi legittimi.
- **1 regola Sigma Critical + 7 High** → il valore di severità più alto dei 5 campioni. Le regole Sigma lavorano sui log di sistema (Sysmon, Event Log), quindi questo indica comportamenti chiaramente riconoscibili a livello di processo/registro.
- Il dropped **LNK** è tipico: i file `.lnk` nella cartella Startup sono un metodo di persistenza alternativo alle chiavi Run.
- `obfuscated + exploit + persistence + calls-wmi` → set di capacità completo.

Tecniche MITRE rilevanti: T1219 (Remote Access Software), T1572 (Protocol Tunneling), T1547.001 (Registry Run Keys / Startup Folder), T1027 (Obfuscated Files or Information).

2.3.5 FlashKiller.exe – Trojan

Famiglia: nome non riconducibile a una famiglia nota e documentata. Il nome reale sul disco (`Retrac cheet.exe`) e la dimensione minuscola (**4 KB**) sono i dati più informativi.

Cosa dicono i dati raccolti:

- **4 KB è troppo poco per un payload completo.** Questo è quasi certamente un **downloader/dropper stager**: il suo unico compito è scaricare ed eseguire il payload vero da un server remoto.
- Questo spiega la discrepanza che avevi notato: **detection statica altissima (61/70) ma comportamento dinamico praticamente nullo** (nessuna signature Mitre sopra Info, nessuna regola IDS o Sigma). Le due spiegazioni più probabili:
 1. **Il server di download è offline.** Il campione è vecchio; se il payload di seconda fase non è più scaricabile, il binario non ha nulla da eseguire e la sandbox non osserva nulla di interessante. Questa è l'ipotesi più probabile.
 2. Evasione sandbox (`checks-user-input` suggerisce che attende interazione umana prima di attivarsi – molte sandbox non simulano movimenti mouse/tastiera).
- Il tag `overlay` indica dati appesi oltre la fine strutturale del PE: spesso configurazioni, URL di download o payload cifrato.

Tecniche MITRE rilevanti: T1105 (Ingress Tool Transfer), T1497.002 (Sandbox Evasion: User Activity Based Checks).

2.3.6 Sintesi comparativa

Aspetto	Campione più rappresentativo
Impatto distruttivo	CryptoLocker, Dharma (cifatura dati)
Severità comportamentale	RevengeRAT (Sigma Critical)
Sofisticazione C2	CryptoLocker (DGA) e RevengeRAT (tunnel ngrok)
Evasione difese	Dharma (abuso PCHunter per killare AV/EDR)
Capacità anti-analisi	FlashKiller (comportamento nullo in sandbox)

Tabella 6: Sintesi comparativa dei campioni analizzati

Osservazione trasversale più interessante per il report: nessuno dei 5 campioni comunica con un C2 “classico” (IP hardcoded). Tutti usano meccanismi che rendono il blocco statico inefficace – DGA, tunneling, o download differito. È esattamente il motivo per cui il threat hunting moderno si è spostato dagli IOC atomici (hash, IP) verso gli **indicatori comportamentali (TTP)**: un hash cambia a ogni ricompilazione, ma “questo processo ha fatto 1200 query DNS fallite in 30 secondi” resta valido su tutta la famiglia.

3 Conclusioni

Il laboratorio ha permesso di percorrere l'intero flusso di lavoro tipico di un'analisi malware preliminare, dalla preparazione dell'ambiente fino all'estrazione e alla contestualizzazione degli Indicatori di Compromissione.

3.1 Attività svolte

- **Predisposizione dell'ambiente:** creazione di snapshot della macchina virtuale FlareVM come punto di ripristino sicuro, prerequisito indispensabile prima di manipolare campioni reali.
- **Popolamento del laboratorio:** esecuzione dello script `malwareRepo.ps1` e clonazione del repository di campioni organizzati per categoria di minaccia.
- **Simulazione di persistenza:** creazione manuale di una voce in `HKCU\Software\Microsoft\Windows\CurrentVersion\Run` e verifica dell'esecuzione automatica al riavvio.
- **Analisi statica e triage:** calcolo degli hash SHA256 di 5 campioni (2 Ransomware, 2 RAT, 1 Trojan) e ricerca su VirusTotal.
- **Estrazione IOC:** analisi dei tab *Detection*, *Relations* e *Behavior* e compilazione delle tabelle IOC per ciascun campione.

3.2 Principali risultati

L'analisi ha evidenziato come tutti i campioni esaminati adottino meccanismi di comunicazione con l'infrastruttura di comando e controllo progettati per resistere al blocco statico: algoritmi di generazione dinamica dei domini (DGA), tunneling attraverso servizi legittimi come ngrok, oppure download differito del payload di seconda fase. Nessun campione presenta un indirizzo C2 hardcoded facilmente bloccabile.

Parallelamente, sono emerse tecniche di evasione e di neutralizzazione delle difese ricorrenti: abuso di strumenti legittimi per terminare processi antivirus ed EDR, offuscamento dei no-

mi file, rilevamento dell'ambiente di debug e attesa di interazione utente per eludere l'analisi automatizzata in sandbox.

3.3 Considerazioni finali

L'esperienza pratica di creazione manuale della chiave di persistenza ha fornito una chiave di lettura diretta per interpretare i report di VirusTotal: i tag **persistence** osservati nei campioni corrispondono esattamente al meccanismo sperimentato in prima persona, rendendo concreto un concetto altrimenti astratto.

Il dato più rilevante dal punto di vista difensivo riguarda i limiti degli IOC atomici. Hash e indirizzi IP sono indicatori fragili, facilmente modificabili da un attaccante con una semplice ricompilazione o un cambio di infrastruttura. Gli indicatori comportamentali, ovvero le tecniche, tattiche e procedure (TTP) codificate in framework come MITRE ATT&CK, mantengono invece validità sull'intera famiglia di malware e costituiscono la base del threat hunting moderno.

Le attività svolte hanno inoltre confermato l'importanza metodologica di un ambiente di analisi correttamente isolato e ripristinabile: lavorare su campioni reali senza snapshot e senza isolamento di rete comporterebbe rischi concreti non solo per la macchina di analisi, ma per l'intera rete circostante.